SECURITY ASSESSMENT / MYSCOUTEE

MyScoutee Security Assessment

Tools, methods, and real MyScoutee integration points - a product assessment and decision guide.

Document	MSC-SEC-001 / 1.5.0 / EN
Repository	myscoutee-security
Audience	Developers, operators, and the product owner
Evidence status	Source, image, and passive web checks are available; the web baseline has run on the existing MyScoutee KVM.

Why a separate repository?

Cybersecurity is not a single product to install. Login, authorization, payments, and data handling are owned by the MyScoutee application. This repository assesses the actual product using external checks, methods, and evidence without copying existing implementations.

Trust boundary

Scanners receive source and image inputs read-only. The web baseline uses a versioned local MyScoutee target and checks its identity before starting ZAP. Reports stay in private .local/ state. The assessment does not alter MyScoutee authentication or business rules.

How to read this guide

Start with the next three plain-language pages. Later chapters separate what exists today, what the assessment can test, and what would require a product decision. A clean scanner report is not a security certification.

Start here: the basic ideas

You do not need to know the abbreviations to follow a security check. These words describe what is being protected, what a tool observed, and what was actually fixed.

Term	In plain English	MyScoutee example
Asset, threat, vulnerability	An asset is something worth protecting. A threat could harm it. A vulnerability is a weakness a threat might use.	An account is an asset; an exposed session could let someone act as its owner.
Risk and control	Risk combines possible harm and the chance of it happening. A control reduces that risk.	A session limit or a permission check is a control; neither proves every account is safe.
Authentication / authorization	Authentication checks who you are. Authorization checks whether you may do this action on this item.	A valid login does not grant access to another user's private media.
Container image / Dockerfile	An image is a packaged application plus its operating-system libraries. A Dockerfile describes how to build it.	The nginx source Dockerfile builds MyScoutee's shared proxy image.
Tag / digest	A tag is a human label that can be reused. A digest identifies exact image content.	For a release scan, record the published digest, not only `1.5.0`.
Dependency / patch	A dependency is code or a package the application uses. A patch is a changed version that addresses an issue.	Updating Alpine libraries in the nginx source build can remove known package alerts.
Finding / severity	A finding is what a scanner reports. Severity ranks its potential impact; it is not proof that MyScoutee can be attacked through it.	A HIGH package alert needs a package, version, exposure, and fix decision.
CVE / CVSS / false positive	Common Vulnerabilities and Exposures (CVE) is a public issue ID. The Common Vulnerability Scoring System (CVSS) estimates severity. A false positive does not apply to the target.	Compare affected versions with the package actually inside the image.

Start here: what the results mean

A scanner produces evidence, then a person decides what it means. A source scan checks files and dependencies; an image scan checks the built package; a passive web scan observes responses from a running test site.

The nginx example

Trivy reported 196 package findings in the published MyScoutee 1.5.0 production nginx image. The owning nginx source was updated, a separate 1.5.1 candidate was built, and its Trivy report had zero findings. The published 1.5.0 image did not change. The later production image must also be built and scanned before its result can be claimed.

Word	Meaning	What to do
Triage	Review a finding to decide whether it applies and what action is needed.	Check exact image, package version, available fix, and reachable use.
Fix	Change the owning source or configuration and build a new artifact.	Change the nginx source Dockerfile, then build an image with a new identity.
Verify	Run the relevant tests and rescan the new artifact.	Native nginx tests passed and the 1.5.1 candidate scan was clear.
Scope	The exact thing an observation covers.	A clean native nginx image does not certify every MyScoutee service image.

Read a report safely

Scanner reports may contain secrets, paths, and response data. This assessment keeps JSON and browser-readable HTML under private `.local/reports/`. A scan result is tied to the exact input and scanner version. It does not by itself prove exploitability or a deployed fix.

Start here: events and abbreviations

An audit record is a stored account of an action. A security event is a selected fact used for detection. An alert is a notification raised when a rule matches. Retention says how long records remain; an access boundary says who may read them. Sanitization removes fields that the reader does not need, such as session IDs or bearer tokens.

A SIEM (Security Information and Event Management) collects security events, makes them searchable, and can alert on rules. MyScoutee has no selected or integrated SIEM. The separate Elastic lab is an experiment, not a MyScoutee security-event feed. The current login audit stores sensitive fields and has no defined retention rule in the reviewed source, so it should not be exported as-is.

Acronym decoder

Acronym	Meaning and typical use
SAST / SCA / DAST	Static Application Security Testing checks source; Software Composition Analysis checks dependencies; Dynamic Application Security Testing checks a running app. CodeQL/SonarQube, Trivy, and Zed Attack Proxy (ZAP) are examples.
IAM / MFA	Identity and Access Management controls identities and permissions; Multi-Factor Authentication asks for another proof during login.
WAF / SOC	A Web Application Firewall filters web traffic; a Security Operations Center is a team/process that investigates alerts.
EDR / XDR	Endpoint Detection and Response watches hosts; Extended Detection and Response correlates signals across tools.
NDR / IDS / IPS	Network Detection and Response and Intrusion Detection/Prevention Systems inspect network activity; IPS may block it.
SOAR / PAM / DLP	Security Orchestration, Automation and Response automates approved actions; Privileged Access Management controls powerful accounts; Data Loss Prevention limits sensitive-data movement.
CSPM / CNAPP	Cloud Security Posture Management checks cloud settings; a Cloud-Native Application Protection Platform combines workload and cloud checks.
NIST CSF / ASVS	The National Institute of Standards and Technology Cybersecurity Framework organizes risk work; the Open Worldwide Application Security Project's Application Security Verification Standard lists web-app checks.
MCP / OAuth	Model Context Protocol connects tools to an application; OAuth is a standard for delegated authorization. Both need their own access checks.

OWASP: a practical map

OWASP means Open Worldwide Application Security Project. It is a nonprofit community that publishes open security guidance, standards, and tools. It is not one scanner or a certification. The resources below answer different questions; choose one after naming the MyScoutee behavior to assess.

Resource	Purpose	MyScoutee use
Top 10 / API Top 10	Awareness maps for web and API risks, not pass/fail audits.	Use the 2025 web and 2023 API editions to frame a named MyScoutee question.
ASVS	Testable application security requirements with selectable verification rigor.	Turn a session, actor/resource, or input rule into an expected result.
WSTG	Web security testing scenarios with objectives, method, and evidence.	Choose a focused authentication, authorization, or configuration test.
Cheat Sheet Series	Practical guidance for implementing a specific control.	Consult when changing login, access checks, input handling, or logging.
ZAP	A running-site assessment tool. The baseline crawls and passively checks responses.	Inspect anonymous `/entry` responses and triage private HTML/JSON.
Core Rule Set	Generic attack-pattern rules for a compatible WAF engine.	Optional extension only if the existing nginx scanner controls leave a named threat uncovered.
SAMM	A model for improving security work across the software lifecycle.	Review whether owners define, verify, release, and revisit controls consistently.

How a practitioner combines them

Name an asset, actor, action, and possible harm. Use Top 10 to recognize a broad risk; select an ASVS requirement for the expected control; use a WSTG scenario to design a test; consult a Cheat Sheet for a source-level change. Run ZAP only where a live response can answer the question. Record the target, evidence, owner, fix, and retest. SAMM helps review this cycle over time.

OWASP references: from requirement to test

These publications have different jobs. A risk category is a prompt to investigate; an ASVS requirement states an expected control; a WSTG scenario describes how to examine it. A Cheat Sheet helps implement it. SAMM reviews the development process around those decisions.

Reference	How to use it	MyScoutee record
ASVS 5.0	Choose a versioned, applicable requirement and verification level. Translate its wording into an actor, resource, action, and expected result. Record the exact requirement ID; the chapter name alone is too broad.	For private media, select the applicable access-control requirement; name the owner and a cross-user denial test. No guide-wide ASVS conformance claim is made.
WSTG	Choose a matching test scenario, note its objective and preconditions, then define a safe fixture, request, expected response, and evidence. Test IDs and guide versions keep the case traceable.	Use two disposable users and one private object for an authorization case in the owning backend test. The anonymous ZAP run cannot exercise this case.
Cheat Sheet Series	Consult the topic-specific implementation guidance when changing code. Check its assumptions against the application's own stack and policy; it is guidance, not a test result.	An access-control or output-encoding sheet may guide a source change. Verify the actual policy or rendering behavior with a focused test.
SAMM	Review how Governance, Design, Implementation, Verification, and Operations support the same security decision. Record a current practice, a useful improvement, its owner, and evidence over time.	For release scanning, connect the requirement, build owner, finding triage, exact image digest, and retest. One scanner run does not establish a SAMM maturity level.

Worked path: private media

The possible harm is one member reading another member's media. Select an ASVS access-control requirement for the expected denial; use a WSTG authorization scenario to design the two-actor fixture; inspect the backend policy and test the denied read. If the control fails, consult the relevant implementation guidance, fix the owning source, and repeat the same case. Keep the requirement ID, test path, result, and remaining scope together. This is an assessment method, not a claim that this full path has already run.

OWASP references: logging and edge rules

The Logging Cheat Sheet and Core Rule Set answer different implementation questions. Neither creates an application event contract or a WAF deployment by being cited here.

Reference	Decision and evidence	MyScoutee boundary
Logging Cheat Sheet	Define why an event is needed, then its when, where, who, what, outcome, and intended reader. Exclude or sanitize tokens, session values, passwords, and unnecessary personal data. Test event creation, failure handling, access, retention, and injection-safe encoding.	A proposed operator-login signal needs a product owner, approved fields, retention, and a response rule. Existing login audit data is not approved for wholesale SIEM export.
OWASP CRS	A generic WAF rule set for a compatible engine. Name the request threat, then compare legitimate traffic and a controlled test request. Review rule matches, false positives, sensitive log fields, latency, tuning, and rollback before deciding on blocking.	Existing nginx route, rate, ban, and blocklist controls are assessed first. CRS is only a candidate for a demonstrated gap; it is not installed by this guide.

A minimal logging example

For a failed privileged action, a useful proposed event would identify the operation, time, bounded actor reference, resource class, decision, and reason category. It would not store a bearer token or raw request body. A reviewer would need to know who may read it, how long it remains, and what action a repeated event justifies. These fields are a design example; they do not describe an implemented MyScoutee event.

A minimal CRS evaluation

A rule match is a signal, not proof of an attack. Use a compatible isolated gateway fixture, replay normal login, OAuth, upload, media, and API requests, and inspect one controlled suspicious request. Record blocked legitimate requests and rule exclusions. The decision is whether a named uncovered threat is reduced at an acceptable operational cost.

OWASP Top 10:2025, in product terms

These are risk categories for discussion, not ten test results or a certification. The questions below are examples for MyScoutee; a finding needs a specific actor, request, expected outcome, and evidence.

2025 category	Plain meaning	MyScoutee question
A01 Broken Access Control	An authenticated actor can do or read more than allowed.	Can one user read another user's private media?
A02 Security Misconfiguration	A setting exposes behavior or weakens a control.	What headers and debug routes does the gateway expose?
A03 Software Supply Chain Failures	Dependencies, builds, or delivery may be compromised.	Which exact released image digest and packages were scanned?
A04 Cryptographic Failures	Sensitive data or keys are not protected correctly.	Where are tokens and transport keys handled and stored?
A05 Injection	Input changes how an interpreter handles a command or query.	Does a selected input reach a query or command safely?
A06 Insecure Design	The flow lacks a needed safety rule by design.	Was the access or recovery rule defined before implementation?
A07 Authentication Failures	Login or session proof can be bypassed or reused.	What happens after logout, expiry, or session revocation?
A08 Software or Data Integrity Failures	Code or data crosses a trust boundary without verification.	How are release artifacts and imported data verified?
A09 Security Logging & Alerting Failures	Important activity cannot be detected and acted on safely.	Is a specific approved event and alert defined, without tokens?
A10 Mishandling of Exceptional Conditions	An error path fails open or leaks information.	Does an upstream failure still deny access safely?

The current MSC-130 work has evidence for selected gateway and release questions only. The table does not claim that all ten categories have been tested or that the proposed detection event already exists.

OWASP API Security Top 10:2023

The API list focuses on risks that a normal web Top 10 summary can hide. These selected entries map to existing MyScoutee surfaces; they are questions for the owning backend tests, not vulnerability claims.

API category	Meaning	Focused MyScoutee check
API1 Broken Object Level Authorization	A valid request names an object the actor does not own or may not read.	Use two fixture users and a private media key; expect denial for the other user's object.
API2 Broken Authentication	A token or session is accepted when it should not be.	Exercise one expired or revoked session in the owning auth test.
API3 Broken Object Property Level Authorization	A field is returned or changed without field-level permission.	Check sensitive profile fields in one selected response or update.
API4 Unrestricted Resource Consumption	One operation can consume excessive CPU, storage, money, or calls.	Compare gateway request rate with limits inside a costly operation.
API5 Broken Function Level Authorization	A normal actor reaches an admin or operator function.	Run one focused denial test on a named privileged action.
API9 Improper Inventory Management	Old or unintended API versions and paths remain exposed.	Compare generated public route inventory with deployed endpoints.

BOLA means Broken Object Level Authorization; IDOR means Insecure Direct Object Reference. In both discussions, knowing an identifier does not grant permission. A route allowlist or WAF cannot decide who owns an object; the backend must enforce that rule.

Use ASVS to write the expected control, WSTG to design the negative case, and the owning backend test to observe it. The anonymous ZAP baseline cannot exercise signed-in cross-user access.

OWASP applied to MyScoutee

A tool result is only one piece of evidence. A passive web scan cannot prove that a signed-in user is denied another user's data, and a static requirement cannot show what the running gateway returned.

Case	Method and question	Evidence and limit
Anonymous entry	Use the configured ZAP baseline: which headers, redirects, cache rules, and public responses appear?	2026-10-28 ZAP 2.17.0: zero FAIL, ten WARN groups, 58 PASS. Review the private HTML report per route.
Private media	Use ASVS to state actor/resource denial; follow a WSTG authorization scenario with a safe fixture.	A focused backend negative test can verify one policy path. The anonymous ZAP scan cannot.
Session change	Use ASVS and WSTG to ask what happens after revocation, expiry, or a role change.	Test the owning auth flow; never place tokens in a committed report.
HTML rendering	Trace the source call site for untrusted content and consult output-encoding guidance.	ZAP saw `bypassSecurityTrustHtml(` in a built bundle; no exploitable source path was established.
Web-edge filtering	Review existing nginx route, rate, and IP-ban rules first; select a named uncovered threat before considering CRS.	Native tests cover scanner bans; this assessment has not repeated a live ban test on the KVM.

What to do with the current warnings

Group duplicate observations, identify the source owner, and verify whether the reported behavior matters for a real flow. The gateway exposed an nginx version in the Server header and 404 page; backend and template source configs now hide it. The shared nginx source also limits HTML form submissions to the same origin. A local candidate image passed both gateway tests, but deployment and a ZAP rerun are still needed to verify the running result. The broader CSP and cross-origin headers need a frontend, OAuth, and media policy decision before tightening. Ten WARN groups do not mean ten proven vulnerabilities.

Private evidence and scope

The browser-readable ZAP report is `.local/reports/20261028T011006Z-web-passive-213764/report.html`; sanitized decisions live in the assessment results beside the ordered plan. A new authenticated or active test needs named actors, data limits, target identity, capacity, and an expected result.

1. Methods, tools, operations

Three levels help make sense of the jargon. A method defines what to assess and why; a tool gathers or checks evidence; an operating process turns findings into decisions and verified fixes.

Level	Examples	MyScoutee question
Method	NIST CSF, OWASP ASVS, threat modelling, Zero Trust	Which risk and acceptance condition are we assessing?
Tool	Trivy, CodeQL, SonarQube, ZAP, WAF, SIEM, EDR	What input does it read, and what evidence does it produce?
Operation	SOC, incident response, DevSecOps, backup and restore	Who reviews the result, acts, and verifies the change?

The six functions of NIST CSF 2.0

Govern assigns risk ownership; Identify inventories important systems and data; Protect applies safeguards; Detect finds suspicious activity; Respond handles an incident; Recover restores service. This is an outcomes framework, not a prescribed tool list. OWASP ASVS supplies concrete web-application verification requirements. Together, they help turn MyScoutee use cases into tests.

Example: account takeover

Asset: account and session. Protection: existing backend authentication and a possible second factor. Detection: failed login and factor attempts. Response: revoke the affected session or key. Recovery: restore verified account ownership. Each step needs an owner and evidence.

NIST CSF 2.0 applied to MyScoutee

The CSF Core groups desired outcomes into six Functions, then Categories and Subcategories. Choose relevant outcomes for a real asset and risk; do not treat all outcomes as a compulsory product checklist. The examples below are questions and possible evidence, not assessed results.

Function	MyScoutee question	Owner and useful evidence
Govern (GV)	Who accepts the risk and decides the policy for privileged account access?	Product and deployment owners; named decision, priority, exception, and review date.
Identify (ID)	Which accounts, sessions, services, data, and trust boundaries could an account takeover affect?	Application and deployment owners; scoped asset and data-flow inventory.
Protect (PR)	Which login, session, factor, and actor/resource checks limit misuse?	Owning backend and 2FA teams; configuration and focused allowed/denied tests. The 2FA service is not integrated into login.
Detect (DE)	Which approved signal would distinguish a credible takeover attempt from routine failures?	Event owner; sanitized event definition, detection rule, false-alert review, and reader. No integrated SIEM is claimed.
Respond (RS)	Who can confirm, contain, and communicate an incident?	Incident and account owners; playbook, authorization for revocation, and an incident record.
Recover (RC)	How is access and service restored and checked after containment?	Account and deployment owners; verified ownership, restored access, and the actual installation's recovery evidence.

Profiles and Tiers

A Current Profile records selected CSF outcomes supported by today's evidence; a Target Profile records the desired outcomes and makes gaps visible. Choose them from the real MyScoutee risk, assign an owner and priority, and link each to a control or test. Implementation Tiers describe how consistently risk is governed and managed, from Partial to Adaptive; they are context for the profile, not a security score or certification. This guide has not created a complete MyScoutee Profile or assigned a Tier.

2. Application security tools

Term / tool	Job	MyScoutee integration and status
IAM / MFA	Identity and additional proof	Firebase plus backend session and policy exist. The Go 2FA service runs independently; login does not call it yet.
SAST / CodeQL / SonarQube	Analyze source code	Frontend CodeQL workflow and separate SonarQube runner exist. This repository reuses their results.
SCA / Trivy	Find known dependency vulnerabilities	Runnable now on an explicit source tree and a local release image. Private JSON output.
Secrets scan	Find possible exposed credentials	Trivy source and image scans complement the existing package credential audit.
DAST / ZAP	Inspect a running web app	Only a configured MyScoutee loopback target and an anonymous passive baseline are in scope now. Authenticated testing needs a separate plan.
WAF / edge filtering	Filter web requests at the edge	MyScoutee nginx already blocks route probing and abusive rates; no generic payload-inspection rules are configured.

Replacement or complement?

Keycloak is an IAM replacement candidate only if a specific missing identity requirement and migration plan justify it. The 2FA service would complement existing login. CodeQL, SonarQube, Trivy, and ZAP provide different kinds of evidence; one successful run cannot replace the other layers.

A concrete verification question

Does a 403 response follow the intended actor, workspace, resource, and role rules? A negative backend policy test can prove this for a selected case. A WAF or DAST alert cannot.

3. Web edge: WAF and ZAP

A WAF filters suspicious HTTP traffic at the web edge. MyScoutee already has targeted WAF-like protection inside its nginx gateway. ZAP is an external assessment tool that observes or tests a running site. Neither decides whether a logged-in user may access a workspace or media item; the backend owns that decision.

What MyScoutee already runs

Control	Current behavior	Limit
Route inventory	Known public routes are generated from the application; unknown routes return 404.	A business API 404 on a known route is not scanner evidence.
Rate limits	30 requests/s per IP (burst 120); unknown routes 2/s (burst 10); excess returns 429.	An IP rate is only as reliable as the observed client address.
Scanner IP ban	100 unknown-route or missing-asset attempts within 600 seconds cause a persistent 403 ban.	No automatic expiry; remove a saved entry to clear it. Proxy instances have separate state.
Operator blocklist	IPv4/IPv6 entries can be updated and removed; their message takes priority over an automatic ban.	Requires correct operator state and access to the private blocklist.

The existing native test covers threshold crossing, unaffected clients and internal monitoring, ban persistence, and operator updates. This guide records source and test evidence; it does not claim the current KVM's running ban behavior was retested.

Web edge: coverage and evaluation

What a broader WAF would add

The current edge rules detect route probing and request rate, not generic attack signatures inside request bodies. OWASP CRS is an optional rule set for a compatible WAF engine. Consider it only for a named uncovered threat, with a safe test target and ordinary MyScoutee requests to measure false alarms.

WAF components in plain English

Component	Job	MyScoutee placement or question
Reverse proxy and engine	Receive HTTP traffic and evaluate it before routing.	Existing nginx is the control point; a generic rule engine is optional.
Rule set and policy	Match attack patterns; choose inspect-only or block behavior.	Existing rules cover routes and rates. CRS would add payload signatures.
Audit output and review	Record action, route, time, and rule ID if one exists.	Keep IP and request details private; never export tokens or bodies blindly.
Tuning and rollback	Review false alarms and restore the prior policy if users are blocked.	Check login, OAuth, uploads, media, and API clients before changing rules.

A focused evaluation method

1. Review existing nginx rules and their native tests. 2. Name a threat they do not cover. 3. If an added engine is justified, use a safe test deployment and observation mode first. 4. Replay legitimate login, OAuth, upload, media, and API requests; review false positives and sensitive log fields. 5. Test one controlled hostile request and record detection, latency, rollback, owner, and the decision. No additional WAF engine was installed by this assessment.

Which layer makes which decision?

Layer	Decision	Boundary
Network firewall	Allow or deny an address, port, or connection.	Does not know a MyScoutee object owner.
Existing nginx gateway	Route, request-rate, scanner-IP, and operator-IP decisions.	Does not inspect generic attack payloads.
Optional WAF engine + CRS	Match HTTP attack patterns after TLS termination; observe or block.	May flag valid traffic; needs tuning and a named threat.
Backend authorization	Check identity, role, workspace, and object access.	Must enforce business rules even when edge checks pass.
ZAP	Send assessment requests and report observed behavior.	A testing client, not a deployed request filter.

4. How security capabilities fit together

Each capability has inputs, a decision point, and an owner. The table names the main parts and a concrete MyScoutee question; it does not imply that a candidate is already deployed.

Capability	Typical parts	MyScoutee assessment question
IAM / MFA / PAM	Identity provider, session and policy checks; second-factor verifier; privileged identity and access record.	Who can enter admin/operator paths, and where is each access decision enforced?
SAST / SCA / secrets	Source analyzer; dependency inventory and advisory feed; secret detector; triage owner.	Which source revision or package version is affected, and is a fix available?
Image scan	Built image, immutable digest, package inventory, scanner, finding review.	Does the exact released image contain the reported package?
DAST / ZAP / WAF	Test target and crawler; passive rules; existing nginx route, rate, and ban controls; optional payload rule set.	Which requests trigger current controls, and is a named threat still uncovered?
SIEM / SOC / SOAR	Approved event source, collector, storage, detection rule; analyst queue; response playbook and approvals.	Is there a defined event, reader, retention period, and authorized action? None is specified for operator login detection today.
EDR / XDR	Host agent, policy, alert channel, and containment workflow; correlation across sources.	Which dedicated host signal would justify an investigation?

A security stack diagram is a map of roles, not a required installation order. WAF and nginx act on HTTP requests; host and network sensors may observe in parallel; a SIEM needs an approved event source before it can answer a MyScoutee detection question. The separate CodeForge Elastic lab is not such a source.

5. Network, data, and recovery capabilities

Capability	Typical parts	MyScoutee assessment question
Firewall / IDS / IPS / NDR	Port and route policy; network sensor or traffic feed; signatures or analysis; alert or block action.	What actually reaches the gateway and internal services on the chosen test network?
DLP	Data classification, permitted flows, inspection point, exception and incident review.	Which personal or payment fields could leave through logs, exports, or reports?
CSPM / CNAPP	Cloud or Kubernetes inventory, configuration checks, workload signals, policy owner.	Which deployed platform settings and image identities can be verified?
Threat intelligence	Indicator source, validation, enrichment rule, expiry, analyst decision.	Does a verified indicator add useful context to a real MyScoutee incident?
Backup / recovery	Deployment or host backup, recovery owner, integrity checks, and a restore procedure when required.	Which procedure owns the actual installation? No separate MSC-130 restore is selected.
NIST CSF / ASVS / Zero Trust	Risk owner and outcomes; application verification requirements; request-by-request identity and resource checks.	Which MyScoutee actor, resource, and expected denial are we testing?

One repeatable assessment cycle

Name an asset and actor; draw the trust boundary; select one misuse case; identify the existing control owner; choose the least invasive evidence; set a safe target and data-access limit; run the check; triage false positives and duplicates; change the owning source only for a confirmed issue; retest the same case and record what remains unproven. A tool is useful only when this cycle yields a decision.

6. Operational security tools

Area	What it does	MyScoutee assessment route
SIEM	Collect, search, and alert on security events	None selected or integrated. Elastic Security or Wazuh are examples only.
EDR / XDR	Host protection and cross-source detection	Measurable on a dedicated test host; neither replaces application policy decisions.
NDR / IDS / IPS	Inspect network traffic; optionally block	Suricata or Zeek belongs on an isolated test network with controlled traffic.
SOAR	Automate steps after an alert	Useful once a detection rule and approved response action exist.
PAM / DLP	Privileged access / data loss prevention	Evaluate after an operator-access and sensitive-data-flow inventory.
CSPM / CNAPP	Cloud posture and workload checks	Tie to the deployment model actually used by MyScoutee.
Backup / recovery	Prove data can be restored when a recovery test is in scope	Deployment-owned process; no separate MSC-130 exercise without a named gap.

Role of the existing Elastic lab

myscoutee-elastic demonstrates CodeForge source search and Elastic Stack telemetry. It is a separate data-ingestion lab. No MyScoutee audit data is sent to a selected SIEM by this security sandbox.

21 capabilities: detection and response

This field guide expands the original security list into components, a small test, and a MyScoutee decision. Candidate tools are experiments; their rows do not claim a running product integration.

Area	Typical components	Small verification method	Why it matters here
1. SIEM	Approved event source, collector, index, retention, search, alert rule.	Define one event and expected alert; replay sanitized records; check missed and false alerts, reader, and expiry.	There is no approved MyScoutee operator-login event contract or integrated SIEM. Existing login audit data must not be exported as-is.
2. SOAR	Incident playbook, trigger, human approval, action connector, rollback, audit trail.	Tabletop a synthetic compromised-key alert; require approval before a dry-run revoke and verify rollback.	A real key action belongs to the MyScoutee key owner. Automation waits for a trusted alert and permission boundary.
3. EDR	Host agent, process/file sensor, policy, alert channel, containment owner.	On a disposable host, create a harmless monitored file or process and confirm one alert, overhead, and cleanup.	This tests host visibility for a MyScoutee-like node, not application roles or media authorization.
4. XDR	Two or more approved signal sources, identity/time join, correlation rule, analyst case.	Join synthetic gateway and host/network events; include a similar but unrelated actor to measure false joins.	Cross-source analysis is meaningful only when MyScoutee signal provenance and access rules are known.
5. NDR	Network trace or sensor, flow parser, baseline, alert/review process.	Run Zeek on a sanitized offline trace; compare observed service flows with the expected topology.	May reveal unexpected KVM service connections; encrypted traffic limits what content it can see.
6. IDS	Traffic feed, Suricata rules, alert output, tuning owner.	Replay a suspicious and an ordinary trace offline; compare rule IDs and false positives.	Can detect a chosen network pattern without altering the running MyScoutee gateway.

21 capabilities: prevention and identity

Area	Typical components	Small verification method	Why it matters here
7. IPS	Inline network path, blocking rules, bypass/rollback, operator.	On an isolated path, send one controlled bad and one normal flow; prove block, allow, and rollback.	An inline failure could interrupt MyScoutee traffic; no IPS is inserted into the current KVM.
8. Firewall	Allowed addresses/ports, host or network rules, change owner.	Compare intended exposure with guest listeners and a bounded probe from an approved test network.	Only the intended gateway and administration endpoints should be reachable from each zone.
9. WAF	HTTP decision point, rules, observe/block mode, audit, tuning.	Run existing nginx route, rate, ban, and blocklist tests first. Test an extra rule only for a named uncovered payload threat.	Native nginx already rejects route probing and abusive rates. A broader rule engine needs legitimate-flow false-positive checks.
10. IAM	Identity provider, session, roles, object policy, revocation.	Use two fixture actors and a named resource; verify allowed access, cross-user denial, and revoked-session denial.	Firebase login and backend policy already own MyScoutee decisions; a new identity platform would need a migration case.
11. MFA / 2FA	Factor enrollment, challenge, recovery, rate limit, session binding.	When the product defines its trigger, test allowed and denied login or privileged-action paths in the backend owner.	The sibling 2FA service is separate today. Its integration is a different session and is not claimed here.
12. PAM	Named operator accounts, least privilege, SSH/sudo rules, session record, revocation.	Review who can administer the KVM, releases, and private reports; test revocation only with a disposable account.	Protects powerful deployment access and makes an operator action attributable.

21 capabilities: data and testing

Area	Typical components	Small verification method	Why it matters here
13. DLP	Data classification, permitted destinations, inspection point, exception review.	Put a fake personal-data marker through one approved fixture flow; inspect named logs, exports, and reports.	Finds accidental MyScoutee data leakage without using real member or payment information.
14. Vulnerability scanner	Target inventory, scan profile, advisory data, finding triage.	Run a bounded Greenbone/OpenVAS scan of an approved disposable guest; validate reported service versions.	Can find host/service weaknesses that source and image scans cannot establish; needs capacity and a safe target.
15. SAST	Source revision, analyzer rules, owner review, focused retest.	Review one CodeQL/SonarQube finding in the owning workflow; trace the input to the vulnerable sink.	Supports source-level fixes in frontend or backend; a finding is not proof of a reachable MyScoutee exploit.
16. DAST	Running test target, crawler/request set, passive or active rules, private report.	Use the current anonymous ZAP baseline for headers and responses. Use disposable actors for a later focused authenticated case.	The existing KVM baseline covers the public entry; it does not test cross-user media or admin denial.
17. CSPM	Actual platform inventory, configuration policy, drift review, owner.	Compare Compose/Kubernetes or cloud settings with deployed exposure; run Trivy config checks on the matching manifests.	KVM and deployment configuration matter more than a generic cloud checklist that does not match MyScoutee.

21 capabilities: platform and continuity

Area	Typical components	Small verification method	Why it matters here
18. CNAPP	Workload/image inventory, posture rules, runtime signals, policy owner.	Join an exact image digest with its deployment privileges and exposed services; assess a suite only against this question.	A platform can combine checks, but it cannot replace backend authorization or prove a release image was scanned.
19. Threat intelligence	Indicator source, confidence, expiry, enrichment, analyst decision.	Enrich a synthetic IP/domain/hash and a harmless comparator; check false matches and expiry.	A feed is useful only if it changes a concrete MyScoutee incident decision; it is not evidence of compromise.
20. Secrets management	Secret source, permitted readers, storage, rotation, revocation, audit.	Trace one test key to its consumer; in a fixture, rotate it and prove the old value fails without logging either value.	Applies to MyScoutee integration, database, and release credentials. A Vault server is optional, not the test goal.
21. Backup / recovery	Backup owner, scope, integrity check, restore procedure, recovery objective.	Ask the deployment owner for the actual whole-installation recovery evidence; run a restore only for a named gap on a safe target.	MSC-130 selected no separate restore. The real installation's recovery process owns this capability.

How to choose the next test

Begin with an existing MyScoutee control and one observable question. Prefer source and offline evidence while host capacity is limited. Use the current KVM only for a bounded, approved test. Keep tool proofs on disposable fixtures distinct from product findings. The numbered tests after step 9 in the security test plan give target, method, and evidence for the executable cases.

What the tool references document

The source links at the end describe possible tool behavior. The table connects each one to the assessment's current route or candidate decision; a vendor feature is not evidence that MyScoutee uses it.

Reference	What its documentation helps decide	MyScoutee status and limit
Trivy	Which explicit source, dependency, configuration, secret, or built-image input to scan; which finding needs triage.	Source and local-image scans are runnable. Results cover only the selected input and exact image identity.
ZAP baseline	How a short spider and passive rules inspect reachable responses; how WARN/FAIL classifications and reports work.	The configured anonymous KVM baseline has run. It cannot establish signed-in authorization or active exploitability.
Elastic Security	How approved events become detection rules, alerts, and investigation cases.	Candidate only. The separate CodeForge Elastic lab is not a MyScoutee SIEM or approved event feed.
Suricata / Zeek	Suricata can apply network detection rules; Zeek can analyze traffic and produce structured logs, including from offline traces.	Candidates for an isolated or sanitized network exercise. Neither observes an application policy decision by itself.
Greenbone / Wazuh	Greenbone describes host/service vulnerability assessment; Wazuh documents agent-based host signals such as file integrity monitoring.	Candidates for a bounded disposable host test. No product deployment or integrated alerts are claimed.

What to record when trying a candidate

Name the input and target, version and configuration, owner, expected signal, normal comparator, actual finding, false positives, operational cost, and decision. Keep scanner or event data private. The detailed 21-area tables and ordered test plan provide the small verification route for each capability.

7. A security practitioner's workday

The exact schedule varies by role and team. A security engineer, SOC analyst, and application owner share evidence but make different decisions. This is a practical MyScoutee workflow, not a claim that a staffed SOC already exists.

When	Typical work	MyScoutee evidence and decision
Daily / per alert	Review new alerts and changes; check target identity, timestamps, and duplicates.	Compare auth or key events with a known deployment and actor. Escalate a credible account or key misuse signal.
Per change	Threat-model the changed flow; review access boundaries and test failures.	For an admin or media change, test actor, resource, workspace, and role rules; record the failing or passing case.
Per release	Scan source and accepted image; triage new findings; verify fixes.	Record commit and image digest, affected package, reachable path, owner, decision, and retest result.
Periodic	Review privileged access, logging quality, and deployment recovery evidence.	Check who can read reports and whether the actual installation's recovery owner has suitable evidence.
During incident	Scope, contain, preserve evidence, recover, and review.	Revoke affected session or key through its owning flow; preserve relevant sanitized events; verify access and service recovery.

Worked example: a release-image alert

The first released-image scan produced 196 raw package alerts, including 47 HIGH. This is a queue for triage, not 47 confirmed exploitable vulnerabilities. Select one finding, confirm that the package and image digest belong to the intended release, inspect the fixed version and exposure, then assign an owner and a decision. If changed, rebuild and rescan the exact new digest. Keep a time-bound exception with a reason if remediation must wait.

Minimum finding record

Finding ID and source; observed time; commit or image digest; affected component and MyScoutee use case; evidence and reproduction conditions; severity rationale; owner; decision and deadline; fix or exception; verification result. Store sensitive raw reports privately and share only the minimum evidence needed.

8. Runnable assessment checks

The commands are independent. Source and image inputs must be explicit; the web target comes from versioned config/web-baseline.json and is checked before ZAP starts. The scanner script does not build an application, launch a backend server, or change a fixture.

```
./lab.sh check
./lab.sh scan-source ../myscoutee-backend/config/packaging
./lab.sh scan-image <existing-local-image:tag>
./lab.sh scan-web-passive
```

Command	Input	Output and limit
scan-source	Read-only directory	Trivy JSON: dependencies, configuration, and possible secrets. Separate private cache.
scan-image	Local image via temporary tar	Trivy JSON. No Docker socket in the scanner. The tar is removed.
scan-web-passive	Versioned MyScoutee URL and page identity	ZAP HTML and JSON. One-minute spider, passive checks, no login.

Handling reports

.local/reports can contain secret matches, internal paths, and web response excerpts. Only the appropriate owner should read these reports. Source is mounted read-only and reports are kept out of Git. ZAP may crawl the local web surface, so the versioned target must refer to a designated MyScoutee test deployment.

Interpreting a finding

Record scanner version, target revision or image digest, relevant endpoint, exploit conditions, and the remediation decision. Several scanners may report the same issue; finding counts alone are not a risk ranking.

9. MyScoutee use cases

Use case	Today	Assessment and integration needed
Admin/operator login	Firebase session and backend roles	2FA is runnable separately. Product use needs backend factor policy, origin, recovery, and UI.
API/MCP keys and OAuth	Separate token and authorization flows	Negative key-management tests in the owning backend flow.
Media and personal data	Backend policy and media access	ASVS-driven unauthorized read/upload tests. DLP follows a data-flow inventory.
Release image	Signed release and credential audit	Trivy on the accepted image digest; triage by deployed package and available fix.
Web entry surface	Frontend/nginx plus backend auth	Passive ZAP on a designated local test deployment. Active/auth testing needs a separate scope.
MongoDB/MinIO data	Deployment-owned backup process	No separate MSC-130 restore; reopen for a named recovery gap and owner.

Assessment scope

Use the ordered assessment plan for current checks. An operator-wide security-event feed is not a specified MyScoutee feature and is skipped. A separate restore drill is also skipped: backup and recovery follow the actual deployment or host process, and no recovery gap was identified for this assessment. Host or network tooling requires its own named product question, owner, boundary, and measurable result.

10. Evidence and references

Trivy has run on the published 1.5.0 production nginx image (196 package findings) and a separately built 1.5.1 native nginx candidate (zero findings). The latter is not a published production image. Other service images remain unscanned. ZAP 2.17.0 ran on the actual MyScoutee KVM's anonymous entry page on 2026-10-28: zero FAIL, ten WARN groups, and 58 PASS rules. Its private HTML and JSON require triage before any security conclusion.

Evidence	What it proves	What it does not prove
Scanner JSON/HTML	The scanner ran on a specified input and produced findings.	That every vulnerability is known or exploitable.
Negative policy test	A selected actor/resource case was rejected correctly.	That every authorization path is correct.
Restore exercise	A selected backup was readable and restorable.	That every future backup will be usable.

Primary references

NIST CSF 2.0 Core, Profiles, and Tiers: https://doi.org/10.6028/NIST.CSWP.29

NIST CSF 2.0 FAQs: https://www.nist.gov/cyberframework/faqs

OWASP ASVS 5.0: https://asvs.owasp.org/

OWASP Top 10:2025: https://top10.owasp.org/2025/0x00_2025-Introduction/

OWASP API Security Top 10:2023: https://api-security.owasp.org/editions/2023/en/0x11-t10/

OWASP WSTG: https://wstg.owasp.org/

OWASP Cheat Sheet Series: https://cheatsheetseries.owasp.org/

OWASP SAMM: https://owasp.org/projects/samm

OWASP Logging Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

ZAP Docker Baseline: https://www.zaproxy.org/docs/docker/baseline-scan/

OWASP CRS documentation: https://coreruleset.org/docs/

Trivy: https://trivy.dev/latest/docs/

Elastic Security: https://www.elastic.co/docs/solutions/security

Suricata offline and inline modes: https://docs.suricata.io/en/latest/command-line-options.html

Zeek offline trace analysis: https://docs.zeek.org/en/lts/quickstart.html

Greenbone Community Edition: https://greenbone.github.io/docs/latest/index.html

Wazuh file monitoring example: https://documentation.wazuh.com/current/proof-of-concept-guide/poc-file-integrity-monitoring.html

Product sources: myscoutee-nginx, myscoutee-backend, myscoutee-2fa, myscoutee-elastic, myscoutee-sonarqube, and myscoutee-ci. Verify exact versions and integration status against the current repository sources.